

DOKUMEN PERENCANAAN PENGEMBANGAN

SkinSync

Website E-Commerce Penjualan Skincare

Direct-to-Consumer untuk Pasar Indonesia

Jenis Dokumen	Dokumen Perencanaan & Spesifikasi Sistem
Versi	1.0
Tanggal	4 Oktober 2026
Disusun oleh	Waridatul Jannah
Link website	https://skinsync-production-71c1.up.railway.app/

Daftar Isi

Daftar Isi	1
1. Pendahuluan	3
1.1 Latar Belakang	3
1.2 Tujuan	3
1.3 Ruang Lingkup	3
1.4 Batasan (Di Luar Ruang Lingkup)	3
1.5 Definisi dan Istilah	4
2. Gambaran Umum Sistem	5
2.1 Identitas Sistem	5
2.2 Prinsip Arsitektur	5
2.3 Aturan Bisnis Utama	5
2.4 Alur Nilai Utama (Happy Path)	5
3. Pemangku Kepentingan dan Peran Pengguna	7
3.1 Peran Pengguna	7
3.2 Penegakan Hak Akses	9
3.3 Manajemen Sesi	9
3.4 Matriks Hak Akses	9
4. Analisis Kebutuhan	10
4.1 Kebutuhan Fungsional	10
4.2 Kebutuhan Non-Fungsional	11
5. Arsitektur dan Teknologi	12
5.1 Tumpukan Teknologi	12
5.2 Catatan Arsitektur	13
5.3 Struktur Folder	13
6. Perancangan Basis Data	14
6.1 Enumerasi	14
6.2 Entitas Identitas dan Alamat	15
6.3 Entitas Katalog	15
6.4 Entitas Keranjang, Ongkir, dan Voucher	15
6.5 Entitas Pesanan dan Pembayaran	16
6.6 Entitas Konten, Notifikasi, dan Sistem	16
6.7 Data Awal (Seed)	16
7. Alur Bisnis dan Proses	17
7.1 Autentikasi OTP WhatsApp	17
7.2 Katalog Produk	18
7.3 Keranjang	18
7.4 Checkout dan Pembuatan Pesanan	18
7.5 Voucher	20

7.6 Pembayaran dan Webhook Midtrans	19
7.7 Siklus Status Pesanan dan Pemenuhan	21
7.8 Kedaluwarsa Otomatis	22
7.9 Ulasan Pelanggan.....	23
8. Perancangan API	25
8.1 Autentikasi dan Sesi.....	25
8.2 Keranjang	25
8.3 Pesanan, Pembayaran, Voucher, dan Ulasan.....	25
8.4 Akun	26
8.5 Admin	26
8.6 Infrastruktur.....	27
9. Perancangan Antarmuka dan Halaman.....	28
9.1 Halaman Publik	28
9.2 Autentikasi, Belanja, dan Akun	28
9.3 Panel Admin.....	28
10. Validasi, Keamanan, dan Audit.....	30
10.1 Validasi Input (Zod).....	30
10.2 Kontrol Keamanan	30
10.3 Audit Log	30
11. Notifikasi WhatsApp (Fonnte)	31
12. Pengelolaan Gambar dan Penyimpanan.....	31
12.1 Penyimpanan	31
12.2 Unggah (POST /api/admin/upload)	31
12.3 Penyajian	31
13. Operasional: Cron dan Health Check	32
14. Lingkungan dan Deployment	33
14.1 Variabel Lingkungan.....	33
14.2 Deployment (Railway).....	33
14.3 Tahapan Pengembangan (Usulan)	35
15. Rencana Pengujian dan Kriteria Selesai	36
16. Manajemen Risiko.....	38

1. PENDAHULUAN

1.1 Latar Belakang

Pertumbuhan belanja daring produk perawatan kulit di Indonesia mendorong brand untuk memiliki kanal penjualan langsung kepada konsumen (direct-to-consumer/DTC) yang tidak bergantung pada marketplace. Kanal milik sendiri memberi kendali penuh atas pengalaman pelanggan, data, harga, dan kepatuhan informasi produk (misalnya nomor BPOM).

SkinSync dirancang sebagai website e-commerce satu brand skincare dengan alur belanja yang sederhana namun andal: pelanggan masuk menggunakan OTP WhatsApp, berbelanja, membayar melalui Midtrans, dan menerima pembaruan status pesanan melalui WhatsApp. Sisi admin dibekali alat untuk mengelola katalog, stok, pesanan, ongkos kirim, voucher, ulasan, dan laporan.

1.2 Tujuan

1. Menyediakan kanal penjualan DTC yang sederhana dan andal untuk satu brand skincare.
2. Menjamin konsistensi stok, pesanan, dan pembayaran melalui transaksi basis data serta webhook yang idempoten.
3. Mengurangi pekerjaan operasional manual melalui notifikasi WhatsApp otomatis, cron kedaluwarsa/auto-complete, dan dashboard admin.

1.3 Ruang Lingkup

Sistem mencakup fungsi-fungsi berikut:

- Katalog publik: pencarian, filter (kategori, jenis/masalah kulit, brand, harga), pengurutan, paginasi, dan halaman detail produk beserta nomor BPOM dan ulasan terverifikasi.
- Autentikasi OTP WhatsApp (login sekaligus registrasi) dengan sesi cookie JWT berlaku 30 hari.
- Keranjang belanja per pengguna, buku alamat, checkout, voucher, dan ongkos kirim flat per zona.
- Pembayaran Midtrans Snap, webhook pembayaran, dan tombol bayar ulang.
- Pemenuhan pesanan oleh admin: perubahan status, input kurir/resi, catatan, dan riwayat notifikasi WhatsApp.
- Ulasan produk terverifikasi dengan moderasi admin dan agregasi rating.
- Panel admin: produk/varian/gambar, stok dan pergerakan stok, zona pengiriman, voucher, ulasan, laporan dengan ekspor CSV, pengelolaan admin, serta pengaturan dan template WhatsApp.
- Infrastruktur: health check, tiga cron job, unggah dan penyajian gambar, serta audit log.

1.4 Batasan (Di Luar Ruang Lingkup)

- Tidak ada guest checkout; keranjang dan checkout wajib login.
- Tidak ada notifikasi email; notifikasi hanya melalui WhatsApp (Fonnte).
- Tidak ada integrasi API kurir; ongkos kirim flat per zona dan nomor resi diinput manual.
- Tidak ada flash sale, program loyalitas, wishlist, retur, blog, referral, maupun multi-bahasa.
- Tidak ada modul banner; beranda menggunakan hero statis dan rel produk.
- Ongkos kirim tidak dihitung otomatis dari alamat; pelanggan memilih zona pengiriman aktif secara manual.

1.5 Definisi dan Istilah

Istilah	Penjelasan
DTC	Direct-to-Consumer, penjualan langsung dari brand ke konsumen.
OTP	One-Time Password, kode sekali pakai 6 digit yang dikirim via WhatsApp.
Midtrans Snap	Antarmuka pembayaran Midtrans yang ditampilkan melalui token Snap.
Fonnte	Penyedia gateway WhatsApp yang dipakai untuk mengirim notifikasi.
Webhook	Panggilan HTTP otomatis dari Midtrans ke sistem saat status pembayaran berubah.
Idempoten	Pemrosesan yang aman diulang; kejadian yang sama tidak menimbulkan efek ganda.
Zona pengiriman	Wilayah dengan tarif ongkir flat yang dikelola admin.
BPOM	Badan Pengawas Obat dan Makanan; nomor notifikasi wajib tampil pada produk.
SKU	Stock Keeping Unit, kode unik varian produk.
UTC / WIB	Waktu disimpan dalam UTC dan ditampilkan dalam Asia/Jakarta (WIB, UTC+7).

2. GAMBARAN UMUM SISTEM

2.1 Identitas Sistem

Atribut	Keterangan
Nama sistem	SkinSync website e-commerce direct-to-consumer satu brand skincare
Pasar	Indonesia (Bahasa Indonesia, mata uang IDR)
Jenis aplikasi	Aplikasi monolit Next.js App Router (frontend dan backend dalam satu repositori)
Versi acuan	Next.js 16.3.8, React 19.2.8, Prisma 7.10.0
Mata uang	IDR bertipe Int (tanpa desimal)
Zona waktu	Disimpan UTC, ditampilkan Asia/Jakarta (WIB)

2.2 Prinsip Arsitektur

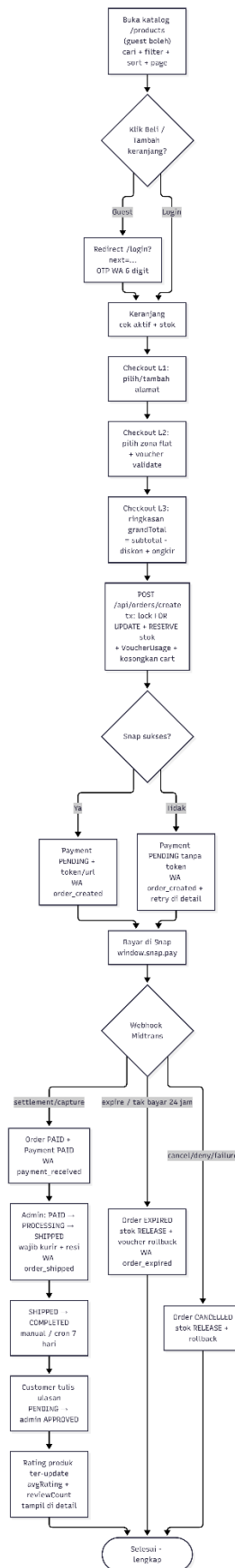
- Logika bisnis ditempatkan pada lapisan service (src/server/services/*).
- Akses basis data hanya melalui satu modul (src/lib/db.ts).
- Seluruh mutasi data dilakukan melalui Route Handlers.
- Validasi input dilakukan di sisi server menggunakan Zod.
- Nilai uang disimpan sebagai Int rupiah; waktu disimpan sebagai UTC.

2.3 Aturan Bisnis Utama

1. Keranjang dan checkout wajib login; tidak ada guest checkout.
2. Voucher hanya dapat digunakan oleh pengguna yang login.
3. Notifikasi hanya melalui WhatsApp (Fonnte), tanpa email.
4. Tidak ada flash sale.
5. Ongkos kirim flat per zona yang diatur admin; nomor resi diinput manual tanpa API kurir.
6. Tidak ada program loyalitas, wishlist, retur, blog, referral, maupun multi-bahasa.

2.4 Alur Nilai Utama (Happy Path)

1. Pengunjung melihat katalog (guest diperbolehkan).
2. Pengunjung menambah ke keranjang; jika belum login diarahkan ke halaman login.
3. Pelanggan menjalani checkout tiga langkah: alamat, zona pengiriman dan voucher, lalu pembayaran.
4. Sistem membuat pesanan secara transaksional: mengunci stok, menghitung total, mereservasi stok, dan membuat data pembayaran.
5. Pelanggan membayar melalui Midtrans Snap.
6. Webhook memverifikasi pembayaran sehingga status menjadi PAID.
7. Admin memproses pesanan (PROCESSING), mengirim dengan resi (SHIPPED, disertai notifikasi WhatsApp), lalu pesanan selesai (COMPLETED) secara manual atau otomatis setelah 7 hari.
8. Pelanggan menulis ulasan; setelah dimoderasi admin, rating produk diperbarui.

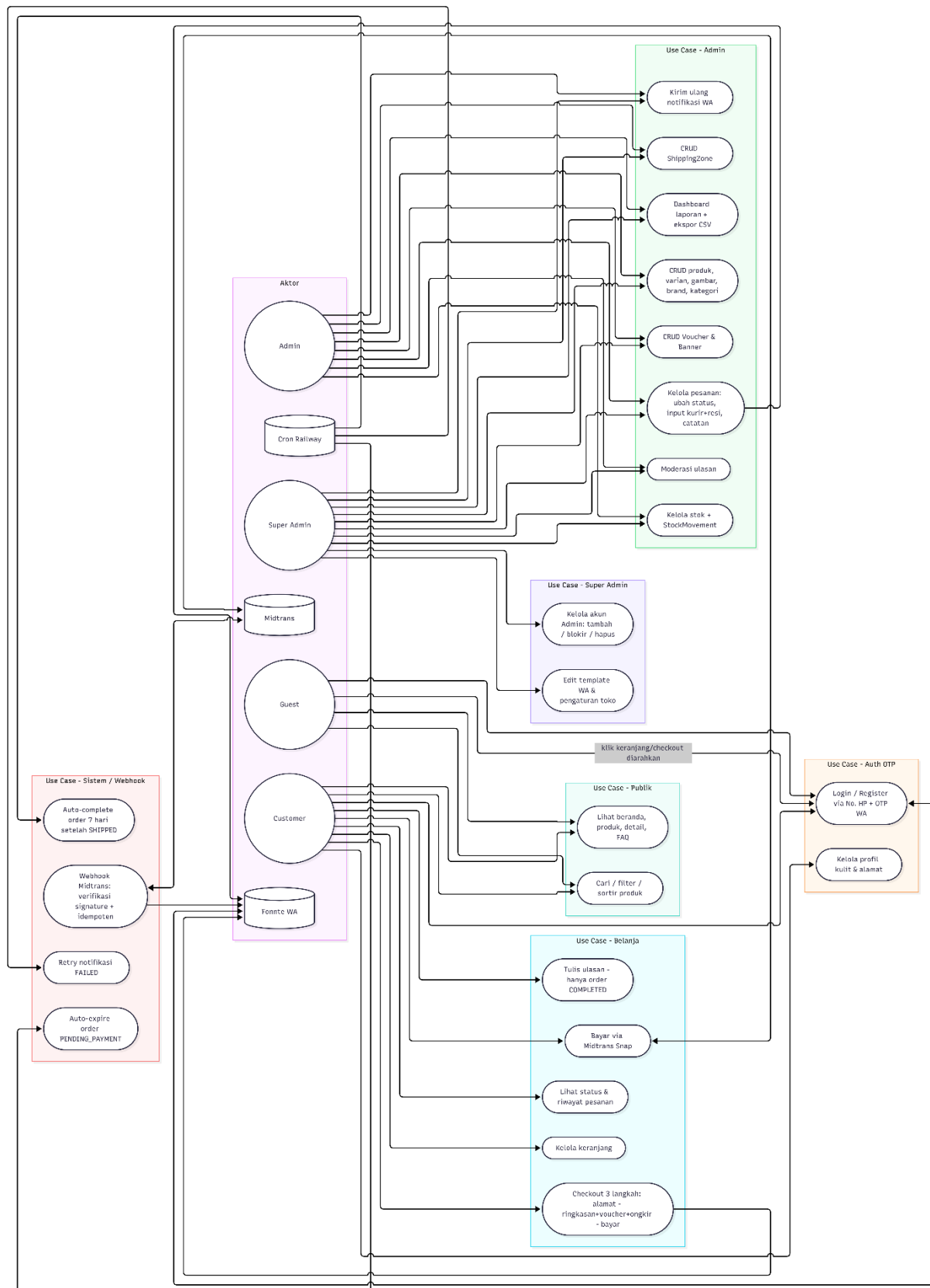


Gambar 2.1 Diagram Alur Nilai Utama (Business Process)

3. PEMANGKU KEPENTINGAN dan PERAN PENGGUNA

3.1 Peran Pengguna

Peran	Hak Akses
CUSTOMER	Berbelanja, mengelola keranjang, checkout, melihat pesanan sendiri, mengelola alamat dan profil kulit, serta menulis ulasan.
ADMIN	Seluruh operasional: produk, stok, pesanan, ongkir, voucher, ulasan, laporan, unggah gambar, dan retry notifikasi.
SUPER_ADMIN	Seluruh hak ADMIN ditambah pengelolaan admin (/admin/users) dan pengaturan sistem serta template WhatsApp (/admin/settings).
Guest (bukan peran DB)	Hanya melihat katalog, FAQ, dan kebijakan; aksi pembelian diarahkan ke halaman login.



Gambar 3.1 Use Case Diagram

3.2 Penegakan Hak Akses

Hak akses ditegakkan pada dua lapisan.

Lapisan Halaman (src/proxy.ts)

Rute	Aturan
/admin/users, /admin/settings	Hanya SUPER_ADMIN. Tanpa sesi diarahkan ke /login?next=; bukan super admin diarahkan ke /admin.
/admin/*	ADMIN atau SUPER_ADMIN. Tanpa sesi diarahkan ke login; CUSTOMER diarahkan ke /.
/checkout, /cart, /account/*	Wajib login.
/login	Jika sudah login diarahkan ke /.

Lapisan API

- requireSession mengembalikan 401 bila tidak ada sesi.
- requireAdmin mengembalikan 403 bila peran bukan ADMIN atau SUPER_ADMIN.
- requireSuperAdmin diterapkan pada endpoint 9dempoten (pengguna admin dan pengaturan).
- Endpoint keranjang, pesanan, voucher, ulasan, dan akun menggunakan getSession().

3.3 Manajemen Sesi

- Cookie httpOnly 9dempot skinsync_session berisi JWT HS256 (9dempot jose).
- Masa berlaku 30 hari; atribut secure aktif di produksi; sameSite=lax.
- SESSION_SECRET wajib minimal 32 karakter.
- Pengguna berstatus BLOCKED tidak dapat login.

3.4 Matriks Hak Akses

Matriks hak akses lengkap (halaman × API × peran) akan dilengkapi pada tahap berikutnya.

Fitur / Endpoint	Guest	Customer	Admin	Super Admin
Lihat katalog & detail produk	Ya	Ya	Ya	Ya
Keranjang & checkout		Ya		
Pesanan & 9dempo sendiri		Ya		
Kelola produk, stok, pesanan, voucher, zona, ulasan			Ya	Ya
Kelola admin & pengaturan sistem				Ya

4. ANALISIS KEBUTUHAN

4.1 Kebutuhan Fungsional

ID	Modul	Kebutuhan
FR-01	Autentikasi	Sistem mengirim OTP 6 digit via WhatsApp; login dan registrasi dalam satu alur; nomor baru otomatis dibuatkan akun.
FR-02	Katalog	Sistem menampilkan daftar produk dengan pencarian, filter, pengurutan, dan paginasi 12 produk per halaman.
FR-03	Katalog	Halaman detail produk wajib menampilkan nomor BPOM, varian, harga, stok, dan ulasan berstatus APPROVED.
FR-04	Keranjang	Pengguna login dapat menambah, mengubah jumlah, dan menghapus item; 10dempo menolak varian nonaktif atau jumlah melebihi stok.
FR-05	Alamat	Pengguna dapat mengelola buku 10dempo dengan satu 10dempo utama.
FR-06	Checkout	Checkout tiga 10dempo: 10dempo, zona pengiriman dan voucher, ringkasan pembayaran.
FR-07	Voucher	Sistem memvalidasi voucher (aktif, periode, minimal belanja, kuota, batas per pengguna) dan menghitung diskon.
FR-08	Pesanan	Sistem membuat pesanan secara transaksional dengan penguncian stok, reservasi stok, dan snapshot 10dempo serta harga.
FR-09	Pembayaran	Sistem membuat transaksi Midtrans Snap, menerima webhook, dan menyediakan bayar ulang untuk pesanan yang belum dibayar.
FR-10	Pemenuhan	Admin mengubah status pesanan sesuai matriks transisi, menginput kurir dan resi, serta mencatat catatan admin.
FR-11	Kedaluwarsa	Pesanan yang tidak dibayar hingga batas waktu otomatis kedaluwarsa; stok dan voucher dikembalikan.
FR-12	Ulasan	Pelanggan dapat mengulas item dari pesanan COMPLETED (satu ulasan per item); admin memoderasi; rating produk diperbarui.
FR-13	Admin Produk	Admin mengelola produk, varian, dan hingga 8 gambar per produk; penghapusan bersifat soft delete.
FR-14	Admin Stok	Admin menyesuaikan stok (IN/OUT/ADJUST) dengan pencatatan pergerakan stok.
FR-15	Admin Master	Admin mengelola zona pengiriman dan voucher.
FR-16	Laporan	Dashboard menampilkan penjualan dan 10dempoten; admin dapat mengekspor pesanan ke CSV.
FR-17	Notifikasi	Sistem mengirim notifikasi WhatsApp untuk OTP, pesanan dibuat, pembayaran diterima, pesanan dikirim, dan pesanan kedaluwarsa.
FR-18	Pengaturan	Super Admin mengelola admin, info toko, masa berlaku pesanan, dan template WhatsApp.
FR-19	Audit	Seluruh 10dempo admin dicatat pada audit log.

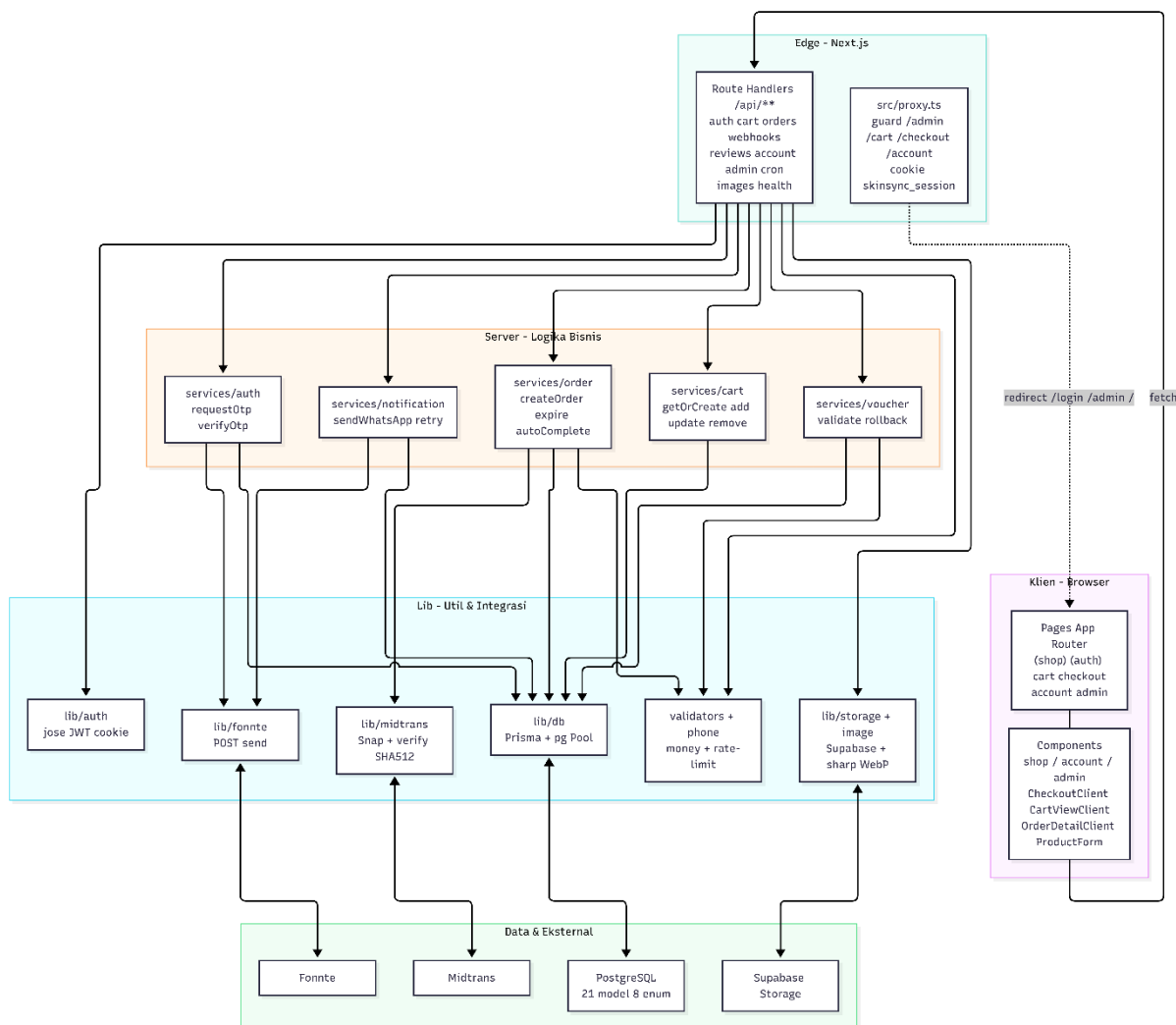
4.2 Kebutuhan Non-Fungsional

ID	Kategori	Kebutuhan
NFR-01	Konsistensi data	Operasi stok, pesanan, dan pembayaran memakai transaksi basis data; perebutan stok dicegah dengan SELECT ... FOR UPDATE.
NFR-02	Keandalan	Kegagalan pengiriman WhatsApp tidak menggagalkan transaksi utama; kegagalan dicatat dan dapat diulang.
NFR-03	Idempotensi	Webhook pembayaran ganda tidak menimbulkan efek ganda dan tidak menurunkan status pesanan.
NFR-04	Keamanan	Semua input divalidasi di server; secret tidak diekspos ke client; OTP disimpan sebagai hash.
NFR-05	Performa	Daftar produk dipaginasi; gambar dikompres ke WebP dan disajikan langsung dari storage 11dempo.
NFR-06	Lokalisasi	Antarmuka berbahasa Indonesia; mata uang IDR; waktu ditampilkan WIB.
NFR-07	Ketertelusuran	Perubahan data admin tercatat pada audit log dengan nilai lama dan baru.
NFR-08	Ketersediaan	Tersedia endpoint health check untuk pemantauan.
NFR-09	Maintainability	TypeScript strict, pemisahan lapisan service, dan migrasi basis data terversi.

5. ARSITEKTUR dan TEKNOLOGI

5.1 Tumpukan Teknologi

Lapisan	Implementasi
Framework	Next.js 16.3.8 App Router, TypeScript strict, React 19
Basis data / ORM	PostgreSQL dengan Prisma 7.10.0 melalui @prisma/adaptor-pg dan pg.Pool
Validasi	Zod 4.6.5 (src/lib/validators/* dan inline pada route)
Autentikasi	OTP WhatsApp kustom dan JWT cookie (jose)
Pembayaran	Midtrans Snap (midtrans-client dan fetch); order_id = orderNumber
Notifikasi	Fonnte API (POST /send), header Authorization tanpa Bearer, delay 2 detik
Penyimpanan gambar	Supabase Storage (public URL) dan sharp untuk pemrosesan gambar
Styling	Tailwind v4 dengan tema editorial kustom
Utilitas	phone.ts (normalisasi 62...), money.ts (Intl id-ID), rate-limit.ts (in-memory fixed window)



Gambar 5.1 Diagram Arsitektur Sistem

5.2 Catatan Arsitektur

- Semua operasi stok, pesanan, dan pembayaran dijalankan dalam `prisma.$transaction`.
- Data Payment selalu dibuat meskipun Snap gagal, agar pembayaran dapat diulang dari halaman pesanan.
- Rate limit OTP bersifat per-IP, ditambah aturan bisnis per nomor telepon.
- Cron dijalankan oleh service terpisah yang memanggil endpoint dengan Bearer `CRON_SECRET`.

5.3 Struktur Folder

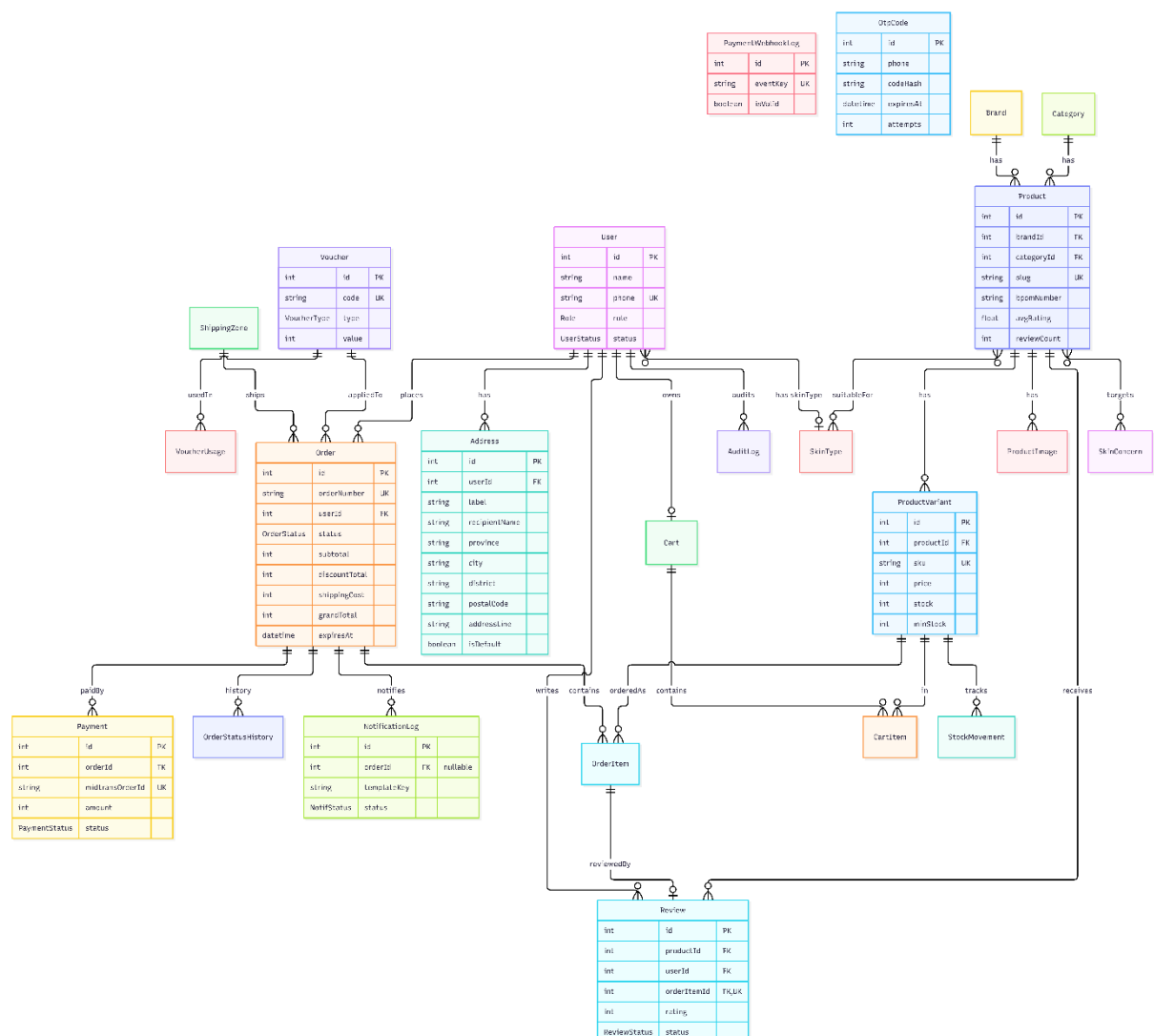
Direktori	Isi
<code>prisma/</code>	<code>schema.prisma</code> (21 model, 8 enum), <code>seed.ts</code> , dan <code>migrations</code> .
<code>Src/proxy.ts</code>	Penjaga rute (pengganti middleware pada Next.js 16).
<code>Src/lib/</code>	<code>db</code> , <code>auth</code> , <code>phone</code> , <code>money</code> , <code>midtrans</code> , <code>fonnte</code> , <code>storage</code> , <code>image</code> , <code>image-url</code> , <code>rate-limit</code> , dan <code>validators</code> .
<code>Src/server/services/</code>	<code>auth</code> , <code>cart</code> , <code>order</code> , <code>voucher</code> , dan <code>notification</code> .
<code>Src/app/(shop)/</code>	Beranda, katalog, detail produk, kategori, FAQ, dan kebijakan.
<code>Src/app/(auth)/login/</code>	Halaman login dua 13dempot.
<code>Src/app/cart, checkout, account/</code>	Keranjang, checkout, dan area akun pelanggan.
<code>Src/app/admin/</code>	Dashboard dan modul pengelolaan admin.
<code>Src/app/api/</code>	Route Handlers: <code>auth</code> , <code>cart</code> , <code>orders</code> , <code>webhooks</code> , <code>vouchers</code> , <code>reviews</code> , <code>account</code> , <code>admin</code> , <code>cron</code> , <code>images</code> , <code>health</code> .
<code>Src/components/</code>	Komponen <code>shop</code> , <code>account</code> , dan <code>admin</code> .

6. PERANCANGAN BASIS DATA

Tipe uang menggunakan Int (IDR) dan seluruh waktu menggunakan DateTime UTC. Skema lengkap tersedia pada `prisma/schema.prisma`.

6.1 Enumerasi

Enum	Nilai
Role	CUSTOMER, ADMIN, SUPER_ADMIN
UserStatus	ACTIVE, BLOCKED
OrderStatus	PENDING_PAYMENT, PAID, PROCESSING, SHIPPED, COMPLETED, EXPIRED, CANCELLED
PaymentStatus	PENDING, PAID, EXPIRED, FAILED
VoucherType	PERCENT, FIXED, FREE_SHIPPING
StockMovementType	IN, OUT, ADJUST, RESERVE, RELEASE
ReviewStatus	PENDING, APPROVED, REJECTED
NotifStatus	QUEUED, SENT, FAILED



Gambar 6.1 Entity Relationship Diagram (ERD)

6.2 Entitas Identitas dan Alamat

Entitas	Atribut Utama	Keterangan
User	id, name, phone (unik, format 62...), role, status, skinTypeId?, allergies?, createdAt, updatedAt	Relasi: skinType, addresses, orders, reviews, cart, auditLogs.
Address	id, userId, label, recipientName, phone, province, city, district, postalCode, addressLine, isDefault	Cascade saat User dihapus.
OtpCode	id, phone, codeHash (SHA256), expiresAt, attempts, usedAt?, createdAt	Index [phone, createdAt].

6.3 Entitas Katalog

Entitas	Atribut Utama	Keterangan
Brand	id, name, slug (unik), logoKey?	Key objek pada bucket.
Category	id, name, slug (unik), sortOrder, isActive	
SkinType / SkinConcern	id, name, slug (unik)	Relasi M-N implisit dengan Product; SkinType juga terkait User.
Product	id, brandId, categoryId, name, slug (unik), description, ingredients, howToUse, bpomNumber, avgRating, reviewCount, isActive, deletedAt?	Index [categoryId, isActive]; soft delete.
ProductVariant	id, 15dempoten, sku (unik), name, price, comparePrice?, weightGram, stock, minStock, isActive	Cascade saat Product dihapus.
ProductImage	id, 15dempoten, key, altText?, sortOrder	Key berformat products/<uuid>.webp.
StockMovement	id, variantId, type, qty, referenceType?, referenceId?, note?, createdBy?, createdAt	referenceType: order atau manual.

6.4 Entitas Keranjang, Ongkir, dan Voucher

Entitas	Atribut Utama	Keterangan
Cart	id, userId (unik), updatedAt	Satu keranjang per pengguna.
CartItem	id, cartId, variantId, qty	Unik [cartId, variantId].
ShippingZone	id, name, province, city?, cost, estimatedDays?, isActive	city null berarti seluruh provinsi.
Voucher	id, code (unik, uppercase), type, value, maxDiscount?, minPurchase, quota?, usedCount, perUserLimit, startsAt, endsAt, isActive	value: persen 1–100 atau nominal; 0 untuk FREE_SHIPPING.
VoucherUsage	id, voucherId, userId, orderId (unik), createdAt	Mencatat pemakaian voucher per pesanan.

6.5 Entitas Pesanan dan Pembayaran

Entitas	Atribut Utama	Keterangan
Order	id, orderNumber (unik, SKN-YYYYMMDD-XXXX), userId, status, subtotal, discountTotal, shippingCost, grandTotal, voucherId?, shippingZoneId, snapshot 16dempo, customerNote?, adminNote?, courierName?, trackingNumber?, shippedAt?, completedAt?, expiresAt	Index [userId, status] dan [status, expiresAt].
OrderItem	id, orderId, variantId, productName, variantName, sku, price, qty, subtotal	Snapshot nama, SKU, dan harga saat pesanan dibuat.
OrderStatusHistory	id, orderId, fromStatus?, toStatus, note?, changedBy?, createdAt	changedBy null berarti 16dempo.
Payment	id, orderId, midtransOrderId (unik, = orderNumber), snapToken?, redirectUrl?, paymentType?, amount, status, paidAt?, expiresAt, rawResponse?	
PaymentWebhookLog	id, eventKey (unik), payload, isValid, processedAt?, createdAt	eventKey = order_id:transaction_status:transaction_id.

6.6 Entitas Konten, Notifikasi, dan Sistem

Entitas	Atribut Utama	Keterangan
Review	id, 16dempoten, userId, orderItemId (unik), rating 1–5, body?, status	Satu ulasan per item pesanan.
NotificationLog	id, orderId?, recipient, templateKey, message, status, attempts, providerResponse?, sentAt?	Index [status, attempts].
Setting	id, key (unik), value (Json)	order_expiry_hours, store_name, store_cs_phone, wa_template:*
AuditLog	id, userId, action, entityType, entityId?, oldValues?, newValues?, createdAt	Jejak seluruh 16dempo admin.

6.7 Data Awal (Seed)

Seed bersifat 16dempotent (upsert/findFirst) dan mencakup:

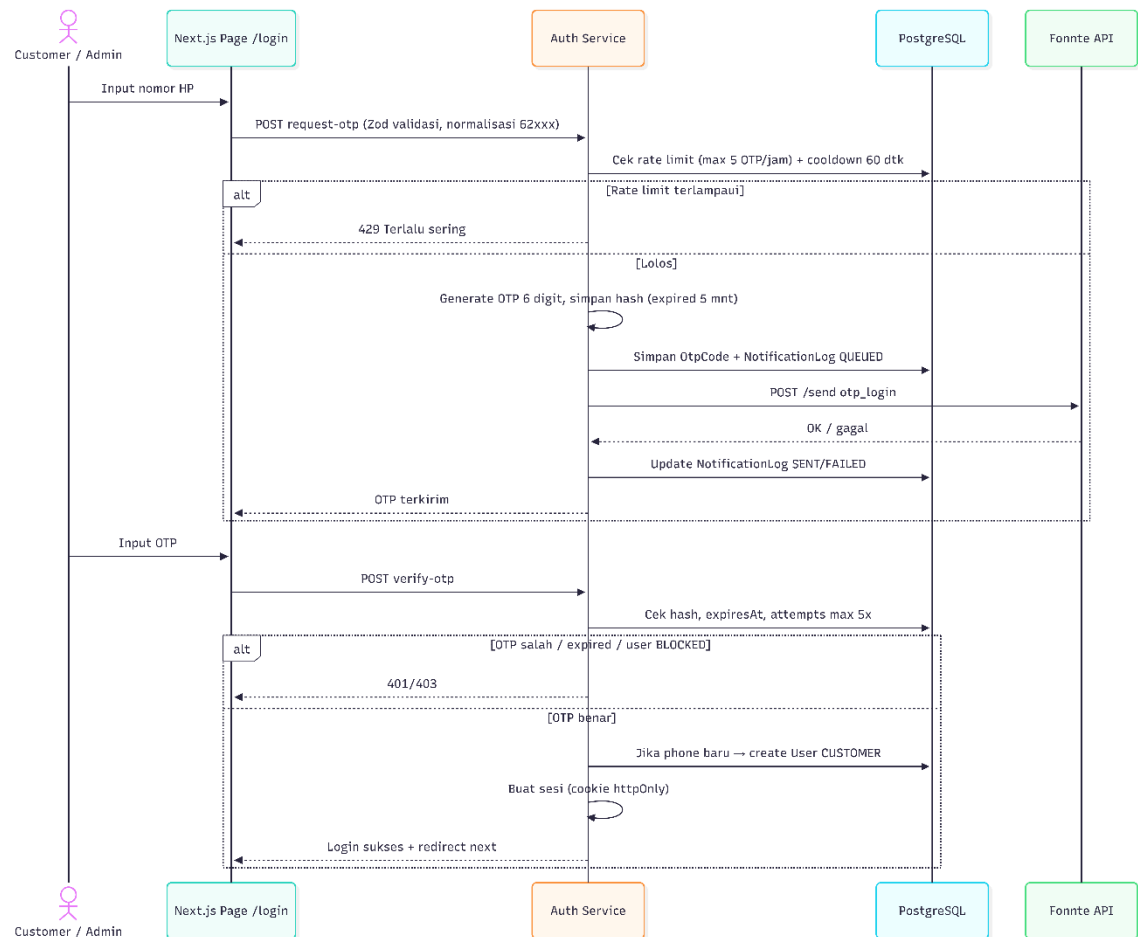
- Super Admin dari SEED_SUPER_ADMIN_PHONE (bawaan 628123456789).
- 5 jenis kulit, 5 masalah kulit, 6 kategori, dan 1 brand (SkinSync Labs).
- 5 zona ongkir flat: Jawa Timur Rp10.000, Jawa Tengah & DIY Rp12.000, Jawa Barat Rp15.000, DKI Jakarta Rp18.000, Luar Jawa Rp30.000.
- 8 pengaturan, termasuk 5 template WhatsApp.
- 2 voucher: WELCOME10 (10%, maksimal Rp25.000, minimal belanja Rp100.000, kuota 500) dan GRATISONGKIR (gratis ongkir, minimal belanja Rp150.000, kuota 200), berlaku 60 hari.
- 4 produk contoh dengan stok 25–60 (cleanser Rp89.000; serum dua varian Rp125.000 dan Rp219.000; moisturizer Rp139.000; sunscreen Rp119.000).

7. ALUR BISNIS dan PROSES

7.1 Autentikasi OTP WhatsApp

Satu alur melayani login sekaligus registrasi. Aturan yang berlaku:

- Nomor telepon dinormalisasi: karakter non-digit dibuang; awalan 0 atau 8 diubah menjadi 62; format valid `/^62[0-9]{8,13}$/`.
- OTP 6 digit (100000–999999) disimpan sebagai hash SHA256, berlaku 5 menit.
- Maksimal 5 percobaan salah per OTP; jeda kirim ulang 60 detik; maksimal 5 OTP per nomor per jam.
- Rate limit per-IP: request-OTP 20 per menit dan verify-OTP 30 per menit (respons 429 bila terlampaui).
- Nomor baru otomatis dibuatkan akun CUSTOMER dengan nama sementara “Pengguna Baru” dan diminta melengkapi nama.
- Pengguna berstatus BLOCKED ditolak. Sesi dibuat pada route verify melalui `setSessionCookie`.



Gambar 7.1 Sequence Diagram Autentikasi OTP

7.2 Katalog Produk

- Parameter daftar: q, category, skinType, skinConcern, brand, sort (newest, rating, price-asc, price-desc), dan page (12 per halaman).
- Filter teks bersifat contains dan tidak membedakan huruf besar/kecil; pengurutan harga dilakukan in-memory.
- Detail produk menampilkan galeri, pilihan varian, harga, stok, deskripsi, komposisi, cara pakai, dan nomor BPOM wajib.
- Hanya ulasan APPROVED yang ditampilkan; produk terkait diambil dari kategori yang sama (4 produk).
- Tersedia tombol WhatsApp CS, JSON-LD Product/Offer, dan metadata judul memuat nomor BPOM.
- Guest yang menekan tombol beli diarahkan ke /login?next=...

7.3 Keranjang

- Satu keranjang per pengguna; seluruh operasi memeriksa kepemilikan.
- Sistem menolak varian atau produk nonaktif/terhapus dan jumlah melebihi stok; jumlah ≤ 0 menghapus item.

7.4 Checkout dan Pembuatan Pesanan

Antarmuka Tiga Langkah

1. Memilih atau menambah alamat pengiriman.
2. Memilih zona pengiriman, menerapkan voucher, dan mengisi catatan.
3. Meninjau ringkasan grandTotal, lalu membayar melalui Midtrans Snap; selanjutnya diarahkan ke halaman detail pesanan.

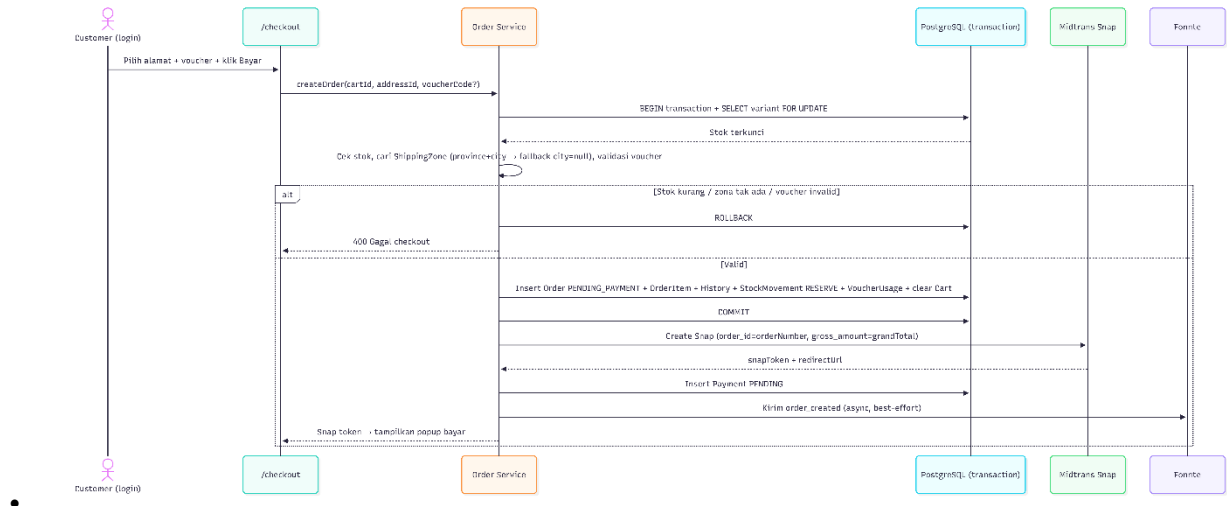
Proses Server createOrder

Seluruh langkah penguncian dan perubahan data berlangsung dalam satu transaksi basis data:

1. Membaca pengaturan order_expiry_hours (bawaan 24 jam).
2. Mengambil keranjang dan item; mengunci varian dengan SELECT ... FOR UPDATE.
3. Memvalidasi varian aktif dan stok cukup; menghitung subtotal = $\sum \text{harga} \times \text{jumlah}$.
4. Menetapkan shippingCost = biaya zona terpilih (zona divalidasi aktif pada route).
5. Memvalidasi voucher dan menghitung discountTotal.
6. Menghitung grandTotal = maks(0, subtotal - diskon + ongkir); menetapkan expiresAt dan orderNumber (SKN-YYYYMMDD-XXXX).
7. Membuat Order berstatus PENDING_PAYMENT beserta OrderItem (snapshot) dan OrderStatusHistory.
8. Mengurangi stok dan mencatat StockMovement RESERVE untuk setiap item.
9. Jika voucher dipakai: membuat VoucherUsage dan menaikkan usedCount.
10. Mengosongkan keranjang.

Setelah transaksi selesai (di luar transaksi):

- Membuat transaksi Snap Midtrans (order_id = orderNumber, gross_amount = grandTotal) tanpa item_details agar tidak terjadi ketidaksesuaian total atau nama panjang.
- Jika sukses: Payment PENDING disimpan beserta snapToken dan redirectUrl. Jika gagal: Payment PENDING dibuat tanpa token dan dapat diulang melalui POST /api/orders/[orderNumber]/pay.
- Mengirim WhatsApp order_created berisi nama, nomor pesanan, total, batas waktu bayar (WIB), dan tautan pembayaran.



Gambar 7.2 Sequence Diagram Checkout & createOrder

7.5 Voucher

Voucher valid bila seluruh kondisi terpenuhi: isActive, waktu saat ini berada dalam [startsAt, endsAt], subtotal $\geq$ minPurchase, usedCount < quota (bila ada), dan jumlah pemakaian pengguna < perUserLimit. Kode disimpan uppercase dan dibandingkan tanpa membedakan huruf besar/kecil.

Tipe	Rumus Diskon
PERCENT	$\text{floor}(\text{subtotal} \times \text{value} / 100)$, dibatasi maxDiscount bila ada
FIXED	$\text{min}(\text{value}, \text{subtotal})$
FREE_SHIPPING	Sama dengan shippingCost (masuk ke discountTotal)

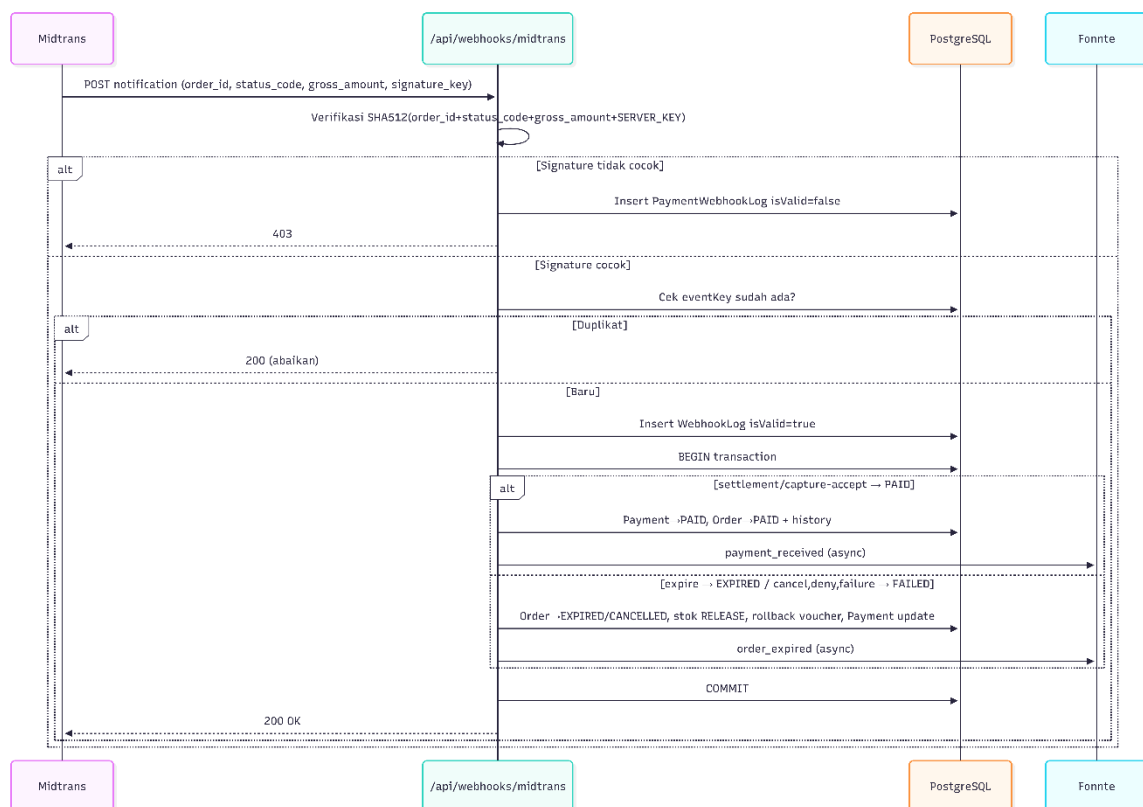
Rollback voucher (saat pesanan EXPIRED/CANCELLED) menghapus VoucherUsage pesanan terkait dan mengurangi usedCount, serta wajib memakai transaksi yang sama bila dipanggil di dalam transaksi.

7.6 Pembayaran dan Webhook Midtrans

- Endpoint publik POST /api/webhooks/midtrans memverifikasi signature_key = SHA512(order_id + status_code + gross_amount + SERVER_KEY). Signature tidak cocok atau tidak ada dicatat isValid=false dan dijawab 403.

- Idempotensi dijamin oleh eventKey unik; kejadian yang sudah diproses dijawab already_processed tanpa efek ganda.
- gross_amount harus sama dengan Payment.amount (400 bila berbeda).
- Anti-downgrade: Order hanya ditransisikan bila status saat ini PENDING_PAYMENT; Payment selalu diperbarui.
- Pengembalian stok (RELEASE) dan rollback voucher hanya terjadi saat transisi ke EXPIRED atau CANCELLED dari PENDING.
- Notifikasi WhatsApp hanya dikirim saat transisi (payment_received dan order_expired). Seluruh proses berlangsung dalam satu transaksi dan processedAt diisi.

Status Midtrans	Order	Payment
settlement / capture (accept)	PAID	PAID
pending	Tidak berubah	PENDING
expire	EXPIRED	EXPIRED
cancel / deny / failure	CANCELLED	FAILED
lainnya	Diabaikan	Diabaikan



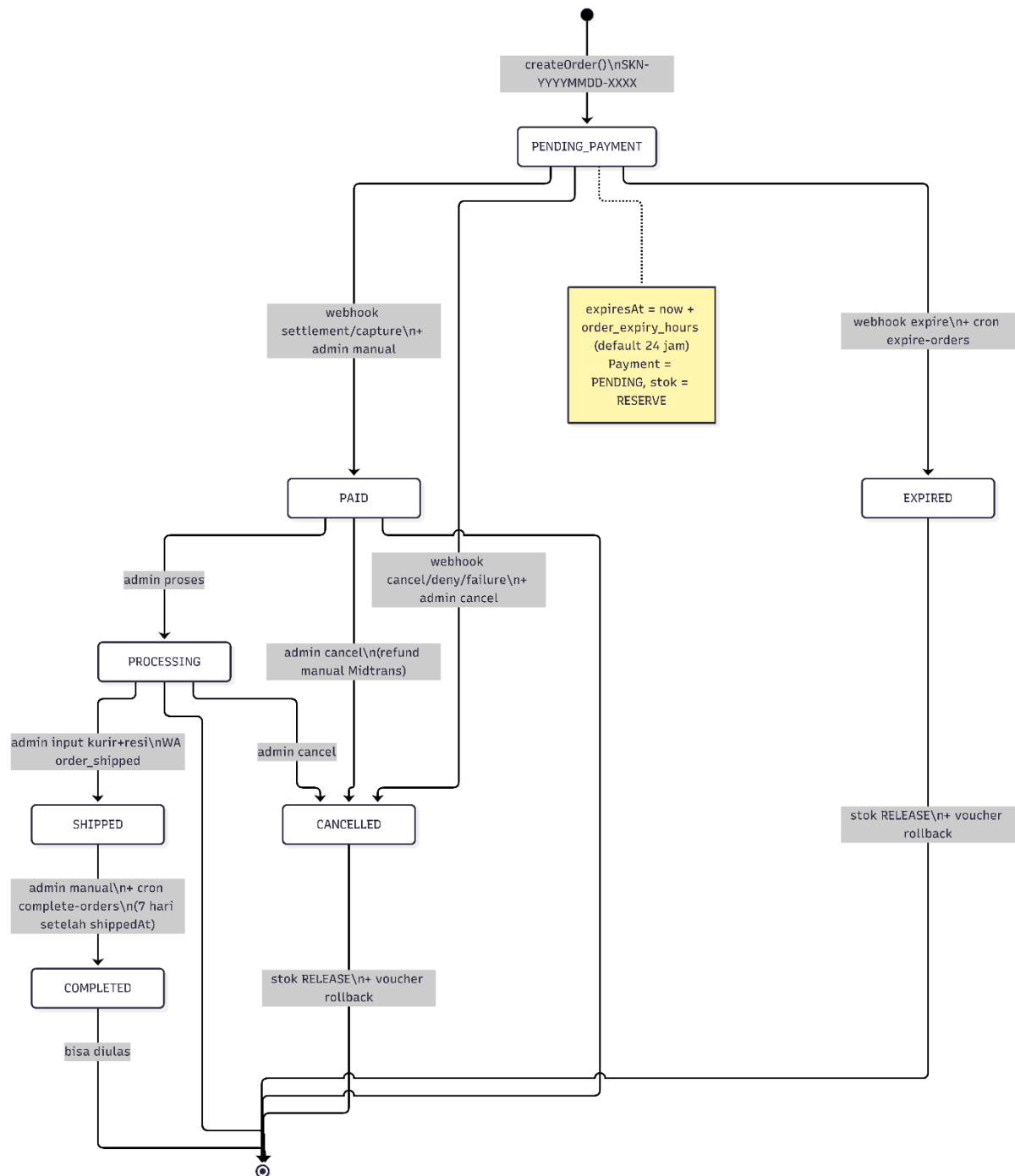
Gambar 7.4 Sequence Diagram Webhook Midtrans

7.7 Siklus Status Pesanan dan Pemenuhan

Perubahan status oleh admin dilakukan melalui PATCH `/api/admin/orders/[id]/status` dengan matriks transisi berikut. Transisi di luar matriks ditolak dengan respons 400.

Status Saat Ini	Status Tujuan yang Diizinkan
PENDING_PAYMENT	PAID, CANCELLED, EXPIRED
PAID	PROCESSING, CANCELLED
PROCESSING	SHIPPED, CANCELLED
SHIPPED	COMPLETED

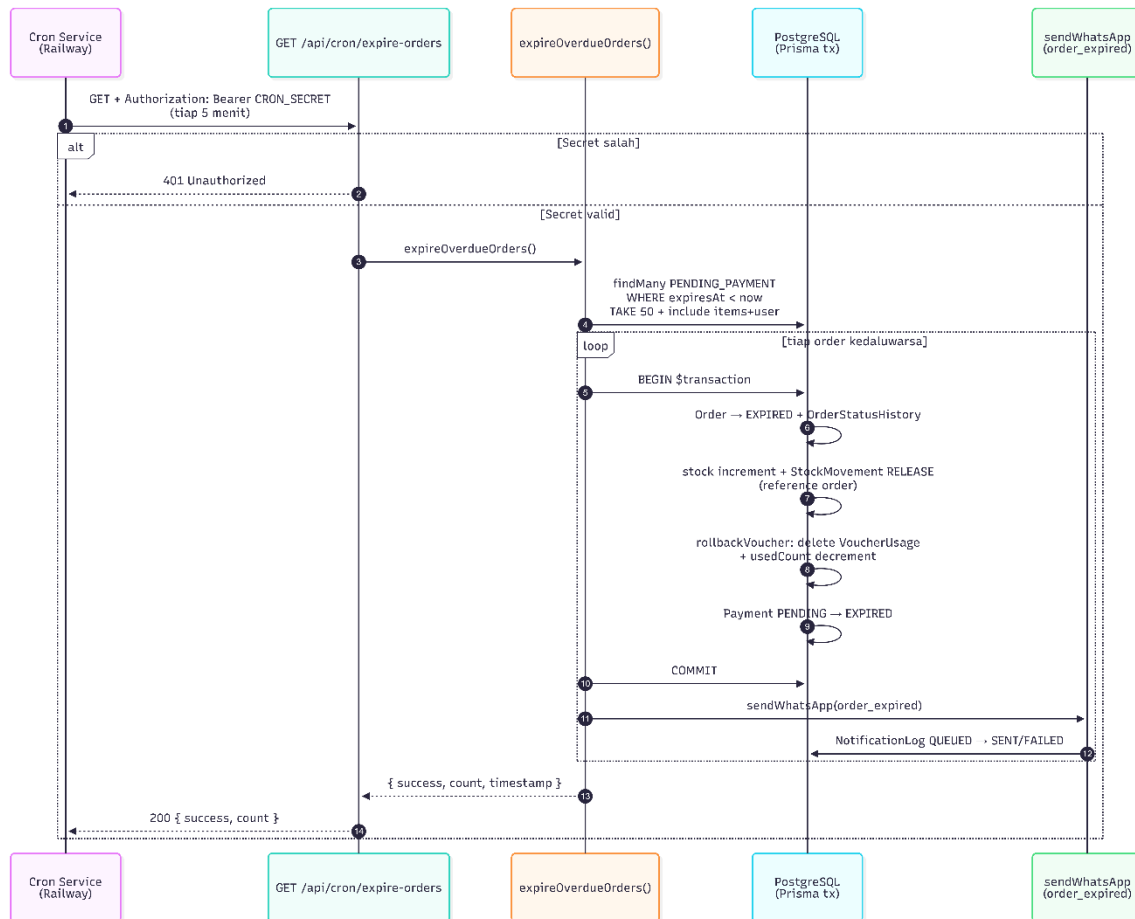
- SHIPPED wajib menyertakan `courierName` dan `trackingNumber` serta memicu WhatsApp `order_shipped`.
- CANCELLED dari PENDING/PAID/PROCESSING (dengan catatan; refund dilakukan manual di dashboard Midtrans) mengembalikan stok (RELEASE), me-rollback voucher, dan mencatat AuditLog.
- COMPLETED dilakukan manual oleh admin atau otomatis 7 hari setelah `shippedAt` melalui cron `complete-orders`.
- EXPIRED terjadi otomatis melalui cron `expire-orders` atau webhook `expire`.



Gambar 7.5 State Diagram Status Pesanan

7.8 Kedaluwarsa Otomatis

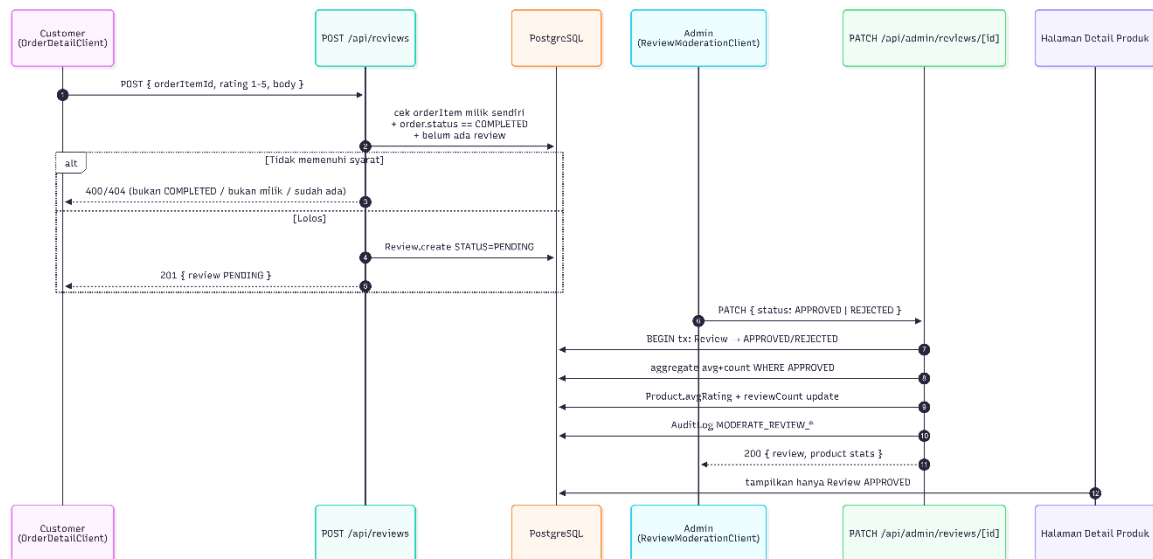
Endpoint GET `/api/cron/expire-orders` (autentikasi Bearer `CRON_SECRET`) mengambil maksimal 50 pesanan `PENDING_PAYMENT` yang `expiresAt`-nya telah lewat. Untuk setiap pesanan, dalam satu transaksi: status diubah menjadi `EXPIRED` beserta riwayat, stok dikembalikan (increment dan `RELEASE`), voucher di-rollback, Payment `PENDING` diubah menjadi `EXPIRED`, kemudian WhatsApp `order_expired` dikirim.



Gambar 7.6 Sequence Diagram Cron Kedaluwarsa Pesanan

7.9 Ulasan Pelanggan

- Syarat: OrderItem milik sendiri pada pesanan COMPLETED, satu ulasan per orderItemId; rating 1–5, isi maksimal 1000 karakter; status awal PENDING.
- Publik hanya melihat ulasan APPROVED.
- Moderasi admin (APPROVED atau REJECTED) memicu penghitungan ulang avgRating dan reviewCount produk serta pencatatan AuditLog.



Gambar 7.7 Sequence Diagram Ulasan & Moderasi

8. PERANCANGAN API

Konvensi kode respons: 401 = tanpa sesi; 403 = sesi ada tetapi peran kurang; 400 = kegagalan validasi atau aturan bisnis; 429 = rate limit atau cooldown; 404 = tidak ditemukan atau bukan milik sendiri.

8.1 Autentikasi dan Sesi

Method & Path	Auth	Keterangan
POST /api/auth/request-otp	Publik (RL 20/mnt per IP)	Input {phone}; membuat OtpCode dan WA otp_login; 429 beserta cooldownSeconds bila cooldown/limit.
POST /api/auth/verify-otp	Publik (RL 30/mnt per IP)	Input {phone, otp}; get/create User; set cookie; mengembalikan {isNewUser, user} atau 401.
POST /api/auth/logout		clearSession() dan mengembalikan {success:true}.

8.2 Keranjang

Method & Path	Auth	Keterangan
GET /api/cart/items	Login	Mengembalikan keranjang, item, varian, produk, dan satu gambar.
POST /api/cart/items	Login	Input {variantId, qty}; memeriksa status aktif dan stok.
PATCH /api/cart/items/[id]	Login	Input {qty ≥ 0}; 0 berarti hapus; memeriksa kepemilikan dan stok.
DELETE /api/cart/items/[id]	Login	Menghapus item milik sendiri.

8.3 Pesanan, Pembayaran, Voucher, dan Ulasan

Method & Path	Auth	Keterangan
POST /api/orders/create	Login	Input {addressId, shippingZoneId, voucherCode?, customerNote?}; mengembalikan {orderNumber, snapToken?, redirectUrl?, midtransError?}.
POST /api/orders/[orderNumber]/pay	Login (milik sendiri)	Ditolak bila bukan PENDING; memakai ulang token bila ada (reused:true); selain itu membuat Snap baru.
POST /api/webhooks/midtrans	Publik (signature)	Verifikasi, idempotensi, dan anti-downgrade.
POST /api/vouchers/validate	Login	Input {code, subtotal, shippingCost}; mengembalikan {valid, voucher, discountAmount}.
POST /api/reviews	Login	Input {orderItemId, rating, body?}; status PENDING; syarat COMPLETED dan milik sendiri.

8.4 Akun

Method & Path	Auth	Keterangan
GET /api/account/addresses	Login	Daftar alamat,urut isDefault menurun.
POST /api/account/addresses	Login	Validasi Zod; mereset default lama; otomatis default bila alamat pertama.
PATCH /api/account/profile	Login	Input {name, skinTypeId?, allergies?}; memperbarui data dan menyegarkan cookie JWT.

8.5 Admin

Seluruh endpoint admin memakai requireAdmin, kecuali pengguna admin dan pengaturan yang memakai requireSuperAdmin.

Method & Path	Keterangan
POST /api/admin/products	Validasi productSchema; cek slug; transaksi pembuatan produk, relasi kulit, varian, imageKeys, dan AuditLog.
PATCH /api/admin/products/[id]	Sinkronisasi varian (hapus bila belum bertransaksi, jika tidak dinonaktifkan; tolak SKU duplikat; movement ADJUST bila stok berubah) dan gambar (maks 8) serta AuditLog.
DELETE /api/admin/products/[id]	Soft delete (deletedAt dan isActive=false); gambar dihapus dari bucket secara best effort.
POST /api/admin/stock/adjust	Input {variantId, qty, type IN OUT ADJUST}; IN = lama + qty ; OUT = maks(0, lama - qty); ADJUST = maks(0, qty); mencatat movement dan AuditLog.
PATCH /api/admin/orders/[id]/status	Matriks transisi 7.7; SHIPPED wajib kurir dan resi; CANCELLED mengembalikan stok dan voucher.
GET/POST /api/admin/shipping-zones; PATCH/DELETE .../[id]	CRUD zona; DELETE ditolak bila dipakai pesanan.
POST /api/admin/vouchers; PATCH/DELETE .../[id]	Kode uppercase; PATCH hanya nilai, batas, kuota, tanggal, dan isActive (kode dan tipe tetap); DELETE ditolak bila sudah terpakai.
PATCH /api/admin/reviews/[id]	Input {APPROVED REJECTED}; memperbarui agregat rating dan AuditLog.
POST /api/admin/users; PATCH/DELETE .../[id] (SUPER)	Membuat ADMIN; mengubah ACTIVE/BLOCKED (tolak diri sendiri); menghapus (tolak diri sendiri dan SUPER_ADMIN).
POST /api/admin/settings (SUPER)	Input {settings:[{key, value}]}; upsert dan AuditLog.
POST /api/admin/upload	Multipart file dan type product brand; maks 5 MB; sharp ke WebP; mengembalikan {key, url}.
GET /api/admin/reports/orders/export	CSV 18 kolom; nama file pesanan-skinsync-YYYY-MM-DD.csv.
POST /api/admin/notifications/[id]/retry	Mengirim ulang satu log notifikasi; hasil SENT atau FAILED.

8.6 Infrastruktur

Method & Path	Keterangan
GET /api/health	SELECT 1; mengembalikan {status:ok, timestamp, database:connected} atau 503.
GET /api/images/[...key]	Validasi isValidKey (404 bila tidak valid), lalu redirect 307 ke URL publik Supabase (kompatibilitas).
GET /api/cron/expire-orders	Bearer CRON_SECRET; menjalankan expireOverdueOrders().
GET /api/cron/retry-notifications	Menjalankan retryFailedNotifications() (FAILED dengan attempts < 3, jeda 1,5 detik).
GET /api/cron/complete-orders	Menjalankan autoCompleteOrders() (SHIPPED lebih dari 7 hari).

9. PERANCANGAN dan HALAMAN

9.1 Halaman Publik

Halaman	Spesifikasi
/ (Beranda)	Hero statis dengan animasi scroll; rel 5 produk (rating tertinggi); 8 kategori; FAQ statis.
/products	Filter, pengurutan, dan paginasi.
/products/[slug]	Metadata dinamis, galeri, varian, BPOM, ulasan APPROVED, produk terkait, tombol WhatsApp CS, dan JSON-LD.
/categories/[slug]	Katalog terfilter kategori.
/faq, /kebijakan/[slug]	Halaman statis (privasi, pengiriman, retur).
sitemap	Dinamis: halaman statis, kategori, dan produk.

9.2 Autentikasi, Belanja, dan Akun

Halaman	Spesifikasi
/login	Dua langkah (nomor HP lalu OTP), awalan 62, timer cooldown; pengguna baru diarahkan ke /account?welcome=1.
/cart	Wajib login; menampilkan keranjang dengan ubah jumlah dan hapus.
/checkout	Wajib login dan keranjang tidak kosong; tiga langkah; memuat skrip Midtrans Snap.
/account	Profil pengguna (nama, jenis kulit, alergi).
/account/addresses	Pengelolaan alamat (tambah, ubah, hapus, set utama).
/account/orders, /account/orders/[orderNumber]	Daftar dan detail pesanan; tombol Bayar; form ulasan bila COMPLETED; resi bila SHIPPED/COMPLETED; riwayat waktu WIB.

9.3 Panel Admin

Halaman	Spesifikasi
/admin (Dashboard)	Penjualan hari ini, kemarin, bulan ini, bulan lalu, dan total; distribusi status; pelanggan baru; 6 pesanan terbaru; 5 produk terlaris; grafik 14 hari; tautan ekspor CSV.
/admin/orders, /admin/orders/[id]	Filter status, pencarian, paginasi 15; detail dan pengelola status dengan kurir/resi/catatan.
/admin/products (+ /new, /[id]/edit)	Daftar, tambah, ubah, dan soft delete produk.
/admin/stock	Varian diurut stok naik; penanda stok $\leq$ minStock; penyesuaian stok; 10 pergerakan terakhir.
/admin/shipping-zones, /vouchers, /reviews	Manajer untuk zona, voucher, dan moderasi ulasan.
/admin/users, /admin/settings (Super Admin)	Pengelolaan admin; pengaturan toko dan template WhatsApp.

10. VALIDASI, KEAMANAN, dan AUDIT

10.1 Validasi Input (Zod)

Berkas	Skema dan Aturan
validators/auth.ts	requestOtpSchema (phone /^62\d{8,13}\$/); verifyOtpSchema (phone, otp 6 digit); updateProfileSchema (name 2–100, skinTypeId? nullable, allergies ≤ 500).
validators/order.ts	addressSchema (label 2–50, recipientName 2–100, phone 9–15, province/city/district ≥ 3, postalCode 5–10, addressLine 10–500); checkoutSchema (addressId, shippingZoneId, voucherCode?, customerNote ≤ 500).
validators/product.ts	productSchema (name 3–200, slug /^[a-z0-9-]+\$/, description ≥ 10, BPOM ≥ 5); productVariantSchema (sku 3–50, price > 0, stock ≥ 0, minStock bawaan 5); stockAdjustSchema (type IN/OUT/ADJUST, note ≤ 500).

10.2 Kontrol Keamanan

- Seluruh input client divalidasi di server; hanya kunci publik yang terekspos ke client (URL/bucket Supabase, Midtrans client key, URL skrip Snap).
- Webhook: verifikasi signature, pemeriksaan jumlah, idempotensi, dan anti-downgrade.
- Upload: hanya admin; isi file diperiksa melalui sharp (bukan sekadar ekstensi); non-gambar ditolak; path traversal dicegah melalui isValidKey.
- OTP disimpan sebagai hash; pembatasan percobaan, cooldown, dan rate limit mencegah penyalahgunaan.
- Cookie sesi httpOnly, secure di produksi, dan sameSite=lax.

10.3 Audit Log

Seluruh mutasi admin dicatat pada AuditLog (userId, action, entityType, entityId, oldValues, newValues). Aksi yang dicatat:

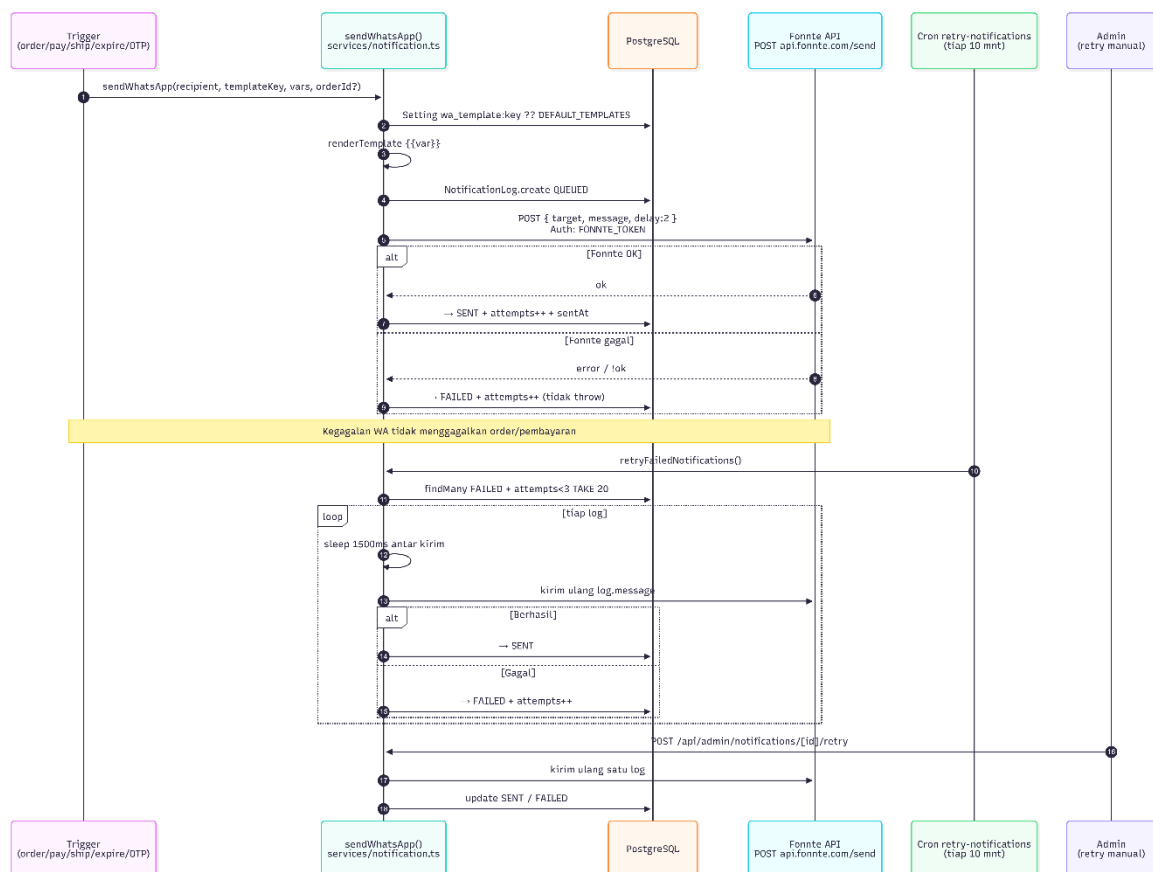
- CREATE_PRODUCT, UPDATE_PRODUCT, SOFT_DELETE_PRODUCT
- UPDATE_ORDER_STATUS, ADJUST_STOCK
- CREATE/UPDATE/DELETE_VOUCHER dan
CREATE/UPDATE/DELETE_SHIPPING_ZONE
- MODERATE_REVIEW_*
- CREATE_ADMIN, CHANGE_STATUS, DELETE_ADMIN
- UPDATE_SYSTEM_SETTINGS

11. NOTIFIKASI WHATSAPP (Fonnte)

Seluruh pengiriman melalui satu fungsi `sendWhatsApp(recipient, templateKey, vars, orderId?)` pada `services/notification.ts`: template dirender, disimpan sebagai QUEUED, dikirim, lalu menjadi SENT atau FAILED tanpa melempar galat. Fungsi `retryFailedNotifications` mengambil maksimal 20 log FAILED dengan `attempts < 3` dan memberi jeda 1,5 detik antar pengiriman.

templateKey	Pemicu	Variabel Utama
otp_login	Permintaan OTP	{{otp}} (berlaku 5 menit, jangan dibagikan)
order_created	Pesanan dibuat	{{name}}, {{orderNumber}}, {{total}}, {{expiresAt}} (WIB), {{paymentUrl}}
payment_received	Status menjadi PAID	{{orderNumber}}
order_shipped	Status menjadi SHIPPED	{{courier}}, {{trackingNumber}}
order_expired	Status menjadi EXPIRED	{{orderNumber}}

Template disimpan pada Setting dengan kunci `wa_template:<key>` dan dapat diubah oleh Super Admin. Bila kosong, sistem memakai `DEFAULT_TEMPLATES` di kode. Render dilakukan dengan substitusi `{{key}}`.



Gambar 11.1 Sequence Diagram Pengiriman Notifikasi & Retry

12. PENGELOLAAN GAMBAR dan PENYIMPANAN

12.1 Penyimpanan

- Menggunakan Supabase Storage dengan URL 31ublic.
- Variabel lingkungan server: SUPABASE_URL, SUPABASE_SERVICE_ROLE_KEY, SUPABASE_STORAGE_BUCKET; sisi client: NEXT_PUBLIC_SUPABASE_URL dan NEXT_PUBLIC_SUPABASE_BUCKET.
- Prefiks yang diizinkan: products/ dan brands/. isValidKey menolak “..”, “/”, dan karakter di luar `^[a-zA-Z0-9/_\-.]+$`.

12.2 Unggah (POST /api/admin/upload)

- Hanya ADMIN; multipart file dan type (product atau brand); ukuran maksimal 5 MB.
- Pemrosesan sharp: validasi JPEG/PNG/WebP, rotate(), hapus EXIF, resize (produk lebar maks 1200 px, brand 400 px, tanpa pembesaran), WebP kualitas 80.
- Key acak <prefix>/<uuid>.webp disimpan dengan upsert; respons {key, url}.
- Penghapusan gambar saat produk atau gambar dihapus bersifat best effort (kegagalan hanya dicatat).
- Batas 8 gambar per produk.

12.3 Penyajian

imageUrl(key) menunjuk langsung ke URL 31ublic Supabase; bila key kosong digunakan /images/placeholder.webp. Route GET /api/images/[...key] hanya memvalidasi dan mengalihkan (307) ke URL 31ublic untuk kompatibilitas.

13. OPERASIONAL: CRON dan HEALTH CHECK

Endpoint	Autentikasi	Jadwal	Fungsi
GET /api/cron/expire-orders	Bearer CRON_SECRET	Tiap 5 menit	expireOverdueOrders()
GET /api/cron/retry-notifications	Bearer CRON_SECRET	Tiap 10 menit	retryFailedNotifications()
GET /api/cron/complete-orders	Bearer CRON_SECRET	Harian	autoCompleteOrders() SHIPPED lebih dari 7 hari menjadi COMPLETED
GET /api/health	Publik	(health check)	SELECT 1; ok/connected atau 503

Cron dijalankan oleh service terpisah (misalnya curl dengan header Authorization) sebagaimana dijelaskan pada Bab 14.

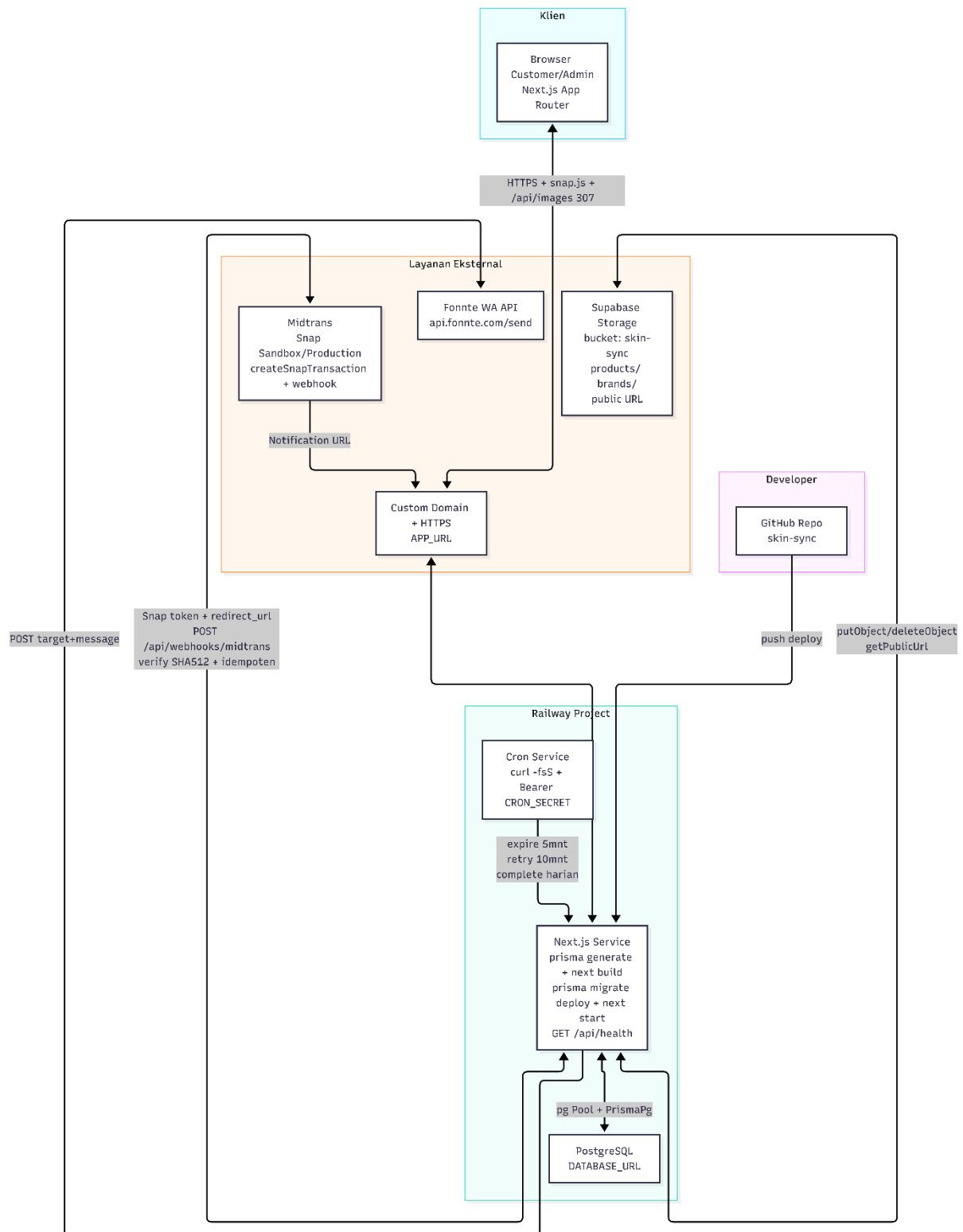
14. LINGKUNGAN dan DEPLOYMENT

14.1 Variabel Lingkungan

Variabel	Keterangan
DATABASE_URL	Koneksi PostgreSQL.
APP_URL	URL dasar aplikasi; dipakai untuk Notification URL Midtrans dan tautan pembayaran.
SESSION_SECRET	Kunci penandatanganan JWT, minimal 32 karakter.
CRON_SECRET	Token Bearer untuk endpoint cron.
MIDTRANS_SERVER_KEY / CLIENT_KEY / IS_PRODUCTION	Kredensial dan mode Midtrans.
FONNTE_TOKEN	Token API Fonnte.
SUPABASE_URL / SERVICE_ROLE_KEY / STORAGE_BUCKET	Konfigurasi storage sisi server.
NEXT_PUBLIC_SUPABASE_URL / NEXT_PUBLIC_SUPABASE_BUCKET	Konfigurasi storage sisi client.
SEED_SUPER_ADMIN_PHONE / NAME	Data Super Admin awal untuk seed.

14.2 Deployment (Railway)

- Satu project berisi service Next.js (dari GitHub) dan PostgreSQL; storage gambar menggunakan Supabase (eksternal). Seluruh secret hanya disimpan pada Railway Variables.
- Build: prisma generate && next build. Pra-start: prisma migrate deploy. Start: next start. Health check: /api/health.
- Domain kustom HTTPS: set APP_URL; Notification URL Midtrans = \${APP_URL}/api/webhooks/midtrans.
- Cron: service terpisah memanggil endpoint dengan Authorization: Bearer \$CRON_SECRET (expire 5 menit, retry 10 menit, complete harian).
- Lingkungan staging memakai Midtrans Sandbox dan terpisah dari production.
- Backup PostgreSQL (pg_dump) dilakukan berkala.



Gambar 14.1 Diagram Deployment

14.3 Tahapan Pengembangan (Usulan)

Fase	Cakupan	Keluaran	Estimasi
1. Fondasi	Skema basis data, seed, autentikasi OTP, guard rute	Login berfungsi; data master tersedia	[diisi]
2. Katalog & Admin Produk	Katalog publik, detail produk, CRUD produk/varian/gambar, stok	Katalog dapat dikelola dan dilihat	[diisi]
3. Transaksi	Keranjang, alamat, checkout, voucher, ongkir, Midtrans, webhook	Pesanan dapat dibuat dan dibayar	[diisi]
4. Pemenuhan & Notifikasi	Status pesanan, resi, WhatsApp, cron kedaluwarsa dan auto-complete	Siklus pesanan lengkap	[diisi]
5. Ulasan & Laporan	Ulasan, moderasi, dashboard, ekspor CSV, kelola admin dan pengaturan	Fitur admin lengkap	[diisi]
6. Pengujian & Peluncuran	UAT, uji beban checkout, deployment produksi	Sistem siap rilis	[diisi]

15. RENCANA PENGUJIAN dan KRITERIA SELESAI

Pengujian dilakukan secara end-to-end pada lingkungan Sandbox. Kolom status diisi saat pengujian berlangsung.

No	Skenario Uji	Hasil yang Diharapkan	Status
1	Guest mengakses cart, checkout, account, dan admin	Akses dibatasi sesuai peran; tombol beli guest mengarah ke login.	☐
2	Alur penuh: cari → keranjang → checkout (± voucher) → Snap Sandbox	Status dan stok terbaru; admin menginput resi; WA resi diterima.	☐
3	Webhook dikirim ganda; gross_amount tidak cocok	Tidak ada efek ganda; mismatch ditolak.	☐
4	Pesanan tidak dibayar hingga batas waktu	Kedaluwarsa otomatis; stok dan voucher kembali.	☐
5	Checkout bersamaan pada stok terakhir	Tidak terjadi overselling (kunci FOR UPDATE).	☐
6	Fonnte gagal saat membuat pesanan/pembayaran	Order dan pembayaran tetap berhasil; retry berhasil.	☐
7	Input tidak valid pada seluruh endpoint	Ditolak oleh validasi Zod; secret tidak terekspos.	☐
8	Upload gambar oleh non-admin dan file non-gambar	Ditolak; gambar valid tampil publik.	☐
9	Deploy dan redeploy	Migrasi otomatis; cron berjalan; webhook produksi diterima; gambar persisten.	☐

Pengujian tambahan yang direkomendasikan: uji beban checkout bersamaan dan uji webhook ganda.

16. MANAJEMEN RISIKO

Risiko	Penjelasan	Mitigasi
Fonnte tidak resmi	Nomor WhatsApp berpotensi diblokir.	Gunakan nomor khusus, hanya pesan transaksional, beri jeda antar pesan, siapkan bantuan OTP manual, dan pertimbangkan WhatsApp Business API resmi saat skala meningkat.
Ongkir flat tidak akurat	Tarif tidak mengikuti tarif kurir aktual.	Tinjau tarif zona secara berkala.
Verifikasi bisnis Midtrans	Proses persetujuan dapat memakan waktu lama.	Ajukan sejak awal pengembangan.
Rate limit in-memory	Hanya efektif pada satu instance.	Gunakan Redis bila berjalan multi-instance.